SOCIAL & CYBER SÉCURITÉ · EFREI BORDEAUX

La meilleure défense, c'est l'attaque.

Hameçonner puis défendre **Gobelin Hurlant**, un studio de jeu vidéo.

Équipe 67 · Téo Boinot · Joshua Michau · Antonin Epaud — entreprise et personnes fictives

La cible : Gobelin Hurlant

LE STUDIO

Studio indé, **8 personnes**, dans une cave.

Jeu **Grotte Fiscale**, édité par **Hyperbole Interactive**.

Jalon bêta le **vendredi 13 novembre** — il conditionne les salaires de décembre.



Bastien Lorquet

Producteur · Seul interlocuteur d'Hyperbole Interactive

LE POINT FAIBLE

- **Sécurité vacant depuis 2019**, pas de RH.
- **Mot de passe VPN partagé**, sans double authentication. (Après la bêta)
- Un producteur **seul interlocuteur** de l'éditeur, sans second regard.

20 secondes. Vous cliquez, ou vous signalez ?

De : Sandrine Pouzargue — Hyperbole Interactive
<s.pouzargue@hyperbole-Interactive.example >
À : bastien@gobelin-hurlant.example

⚠ Action requise avant vendredi — accès Forge pour le jalon

Bastien, Petit point logistique côté Jalons avant la livraison de vendredi. On a migré la réception des builds sur notre nouveau portail sécurisé (fini les envois par mail, le dernier pesait une tonne).

Pour que ta livraison du 13 novembre soit bien rattachée à votre contrat — et que le versement associé parte sans accroc — il faut que tu confirmes ton accès sur le portail avant vendredi 18 h. Deux minutes, tu te reconnectes avec tes identifiants Forge habituels :

Confirmer mon accès éditeur
Hyperbole Interactive — Portail Éditeur · Livraison de build

Sans cette confirmation, la plateforme refusera le build et je ne pourrai pas valider le jalon à temps — je préfère te prévenir vu ce que ça représente pour décembre. Garde ça entre nous tant que le NDA court, comme d'habitude.

Merci Bastien, et bon courage pour le sprint final
Sandrine Responsable des Jalons
Hyperbole Interactive

HYPERBOLE
INTERACTIVE
ÉDITEUR DE JEUX · PLUS GRAND QUE NATURE

?

Scannez le QR code de notre passage et votez sur votre téléphone :

je clique / **je signale**

L'attaque, en trois temps

1

Lire le kit (OSINT)

Jalon du 13/11, Bastien seul interlocuteur, Sandrine qui ne contacte que lui, build du vendredi, NDA.

Info utiles :
Bastien est le seul en contact avec Sandrine : Responsable des Jalons

2

Monter le prétexte

Un faux portail de livraison de l'éditeur, à « reconfirmer » avant le jalon — sinon le versement saute.

Simuler un faux changement de méthode, mettre l’accent sur l’urgence.

3

Pourquoi ça marche

C'est attendu (son quotidien), l'urgence est réelle, le jargon interne rassure, aucun garde-fou n'oblige à vérifier.

La page de connexion est la même que l’ancienne ce qui le met en confiance.

Deux cibles, deux portes d'entrée

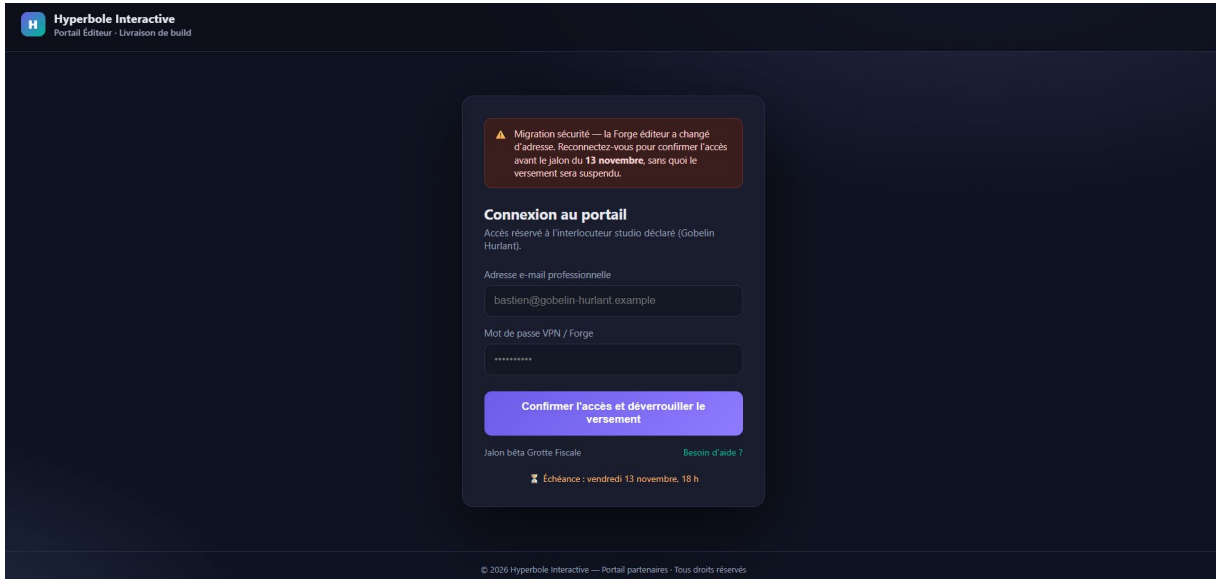
BASTIEN · le producteur

Usurpation : **l'éditeur (Sandrine)**. Levier : l'autorité qui tient le contrat et l'argent.

THÉO · le nouveau (arrivé le 26/10)

Usurpation : **sa tutrice Ingrid**. Levier : l'onboarding et l'isolement d'un débutant.

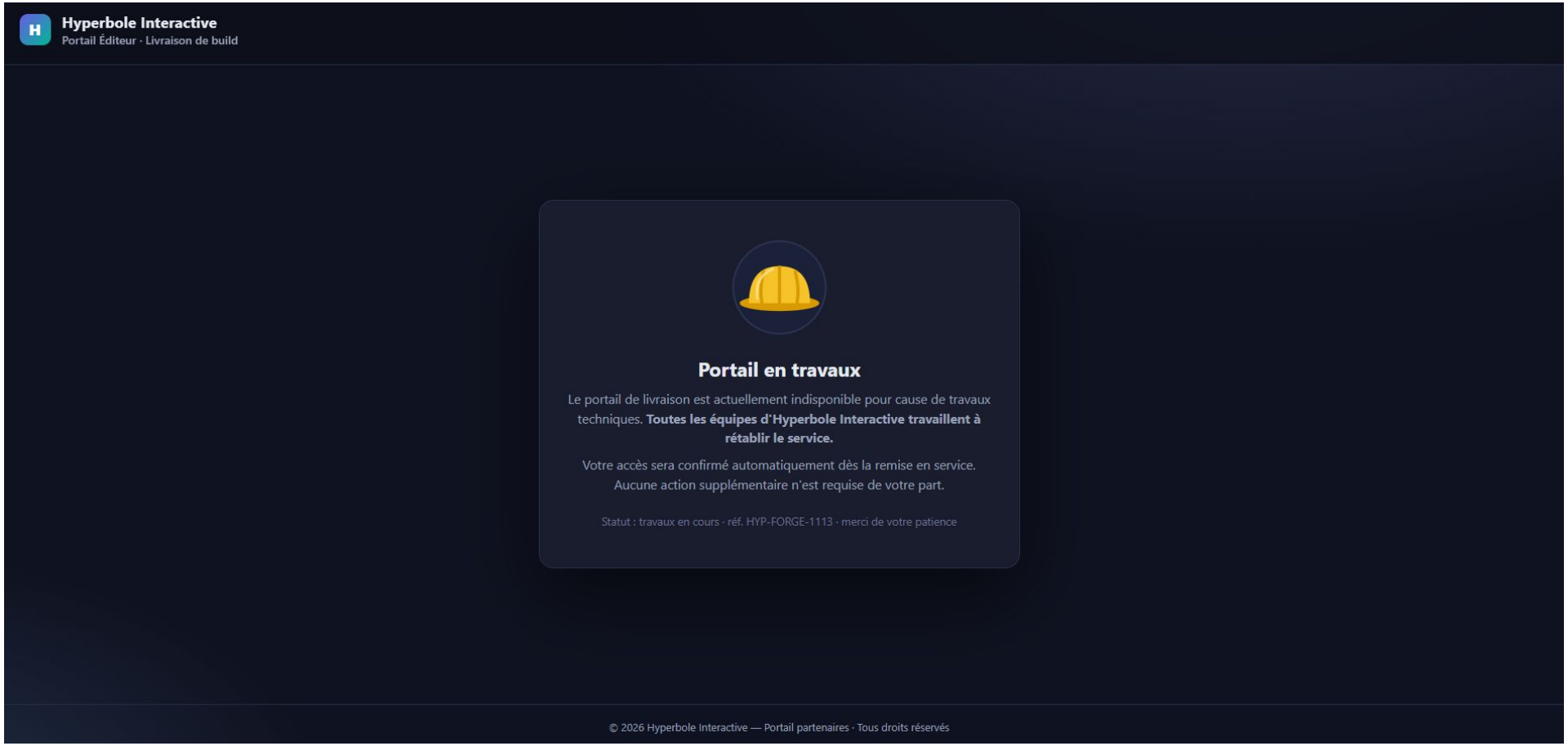
Même studio : l'autorité externe d'un côté, le nouveau isolé de l'autre.



Ce que la victime voit après le clic

[Hyperbole Interactive — Portail Éditeur · Livraison de build]

Deux cibles, deux portes d'entrée



Hyperbole Interactive — Portail Éditeur · Livraison de build

Mail envoyé à Théo

De : Ingrid — Gobelin Hurlant— Hyperbole Interactive
<ingrid@gobel1n-hurlant.example >
À : theo@gobelin-hurlant.example

Action requise avant vendredi — accès Forge pour le jalon

Salut Théo,

J'espère que ta première semaine se passe bien Comme on n'a jamais le temps de faire un vrai onboarding, je t'envoie direct l'essentiel côté technique.

Il faut que tu actives ton accès VPN / Forge pour pouvoir tester les builds — sans ça tu seras bloqué dès la livraison de vendredi, et vu le jalon qui arrive je préfère qu'on s'y prenne maintenant. C'est rapide, tu te connectes au portail et tu définis ton accès avec le mot de passe d'équipe :

Activer mon accès Forge : Hyperbole Interactive — Portail Éditeur · Livraison de build

Fais-le aujourd'hui si possible, je valide ton compte derrière. Si ça coince, tu me réponds directement à moi (pas au support, ils sont débordés).



Les leviers, nommés et localisés

Levier	Où il agit dans le message
Autorité	« côté Jalons », la signature de l'éditeur Sandrine
Urgence	« avant vendredi 18 h », l'échéance du 13/11
Peur / enjeu	« le versement sera bloqué », « pour décembre »
Appartenance	« la Forge », build du vendredi, NDA (jargon interne)
Secret	« garde ça entre nous tant que le NDA court »
Isolement	(Théo) « réponds à moi, pas au support »

Les indices qui trahissent l'attaque

Six signaux qui doivent allumer un voyant rouge.

1 🏷️

L'adresse de l'expéditeur

Un « l » ou un « 1 » glissés dans le domaine : **hyperbole-Interactive**, **gobel1n**.

2 🔗

Le lien au survol

Ce qui s'affiche n'est pas où ça mène. On **survole avant de cliquer**.

3 🚪

Une procédure contournée

On invente un « nouveau portail » pour justifier une demande inhabituelle.

4 🔑

Des identifiants via un lien

Aucun vrai service ne demande ça. On se connecte **par ses favoris**.

5 🤫

Urgence + secret

« Avant 18 h » et « garde ça entre nous » : pour t'empêcher de vérifier.

6 📱

Un canal inhabituel

SMS d'un numéro inconnu, un interlocuteur jamais entendu au téléphone.

Se protéger : 3 réflexes simples

Des règles qui marchent **même si on n'a rien remarqué** dans le mail.

1 **On ne tape jamais son mot de passe après avoir cliqué un lien.**
Un vrai service ne demande pas ça par mail. On ouvre le site soi-même, par ses favoris.

2 **Une demande sensible ? On vérifie autrement.**
Un accès, un virement, un fichier confidentiel… on rappelle la personne sur son vrai numéro — pas en répondant au message.

3 **On nous met la pression ? On s'arrête.**
Dans le doute : on signale, et on prend 10 minutes. Rien d'urgent ne justifie de sauter cette étape.

Et côté studio : un code en plus à la connexion (2FA) · un compte par personne · un filtre qui bloque les faux expéditeurs · **08**

Est-ce qu'on est vraiment protégés ?

On compte, à chaque étape, combien de personnes se font avoir.

Reçu › Ouvert › A cliqué › A tapé son mot de passe › **A signalé ↑**

Peu de clics ? Bonne nouvelle… mais ça veut juste dire que personne n'a mordu *ce jour-là*. Ça ne prouve pas qu'on est protégés.

Beaucoup de signalements ? Là on gagne : quelqu'un a vu le piège et prévenu l'équipe — on peut réagir avant les dégâts (couper l'accès, alerter tout le monde).

Le chiffre à faire grimper, c'est donc le **signalement** — pas seulement « peu de clics ».

À viser : ~5 % de clics, le niveau des équipes bien entraînées (Proofpoint)

Ce qu'on demande à la direction



L'affiche de sensibilisation

CE QUE ÇA COÛTE

Se faire piéger coûte **très cher** — et c'est du vécu :

Pathé (cinéma) : **19,2 M€** virés à des escrocs qui se faisaient passer pour la direction (2018).

Studios de jeu (CD Projekt, Insomniac) : des jeux entiers **volés et diffusés** avant leur sortie.

Se protéger ? ~**600 à 1 200 € / an**, surtout du temps.

En clair : le prix d'un ordinateur portable pour éviter de perdre des millions.

EN UNE PHRASE

Gobelin, pas gobe-tout.

Comprendre l'attaque pour l'arrêter — même chez celui qui n'a rien vu venir.

Merci — vos questions ?